Cloud Incident Response Methodology for AWS Environments

Week 6, Task 23 – Phase A: Theory & Methodology Overview

Objective: understand the NIST SP 800-61r2 incident response lifecycle and how it is adapted to cloud environments on AWS.

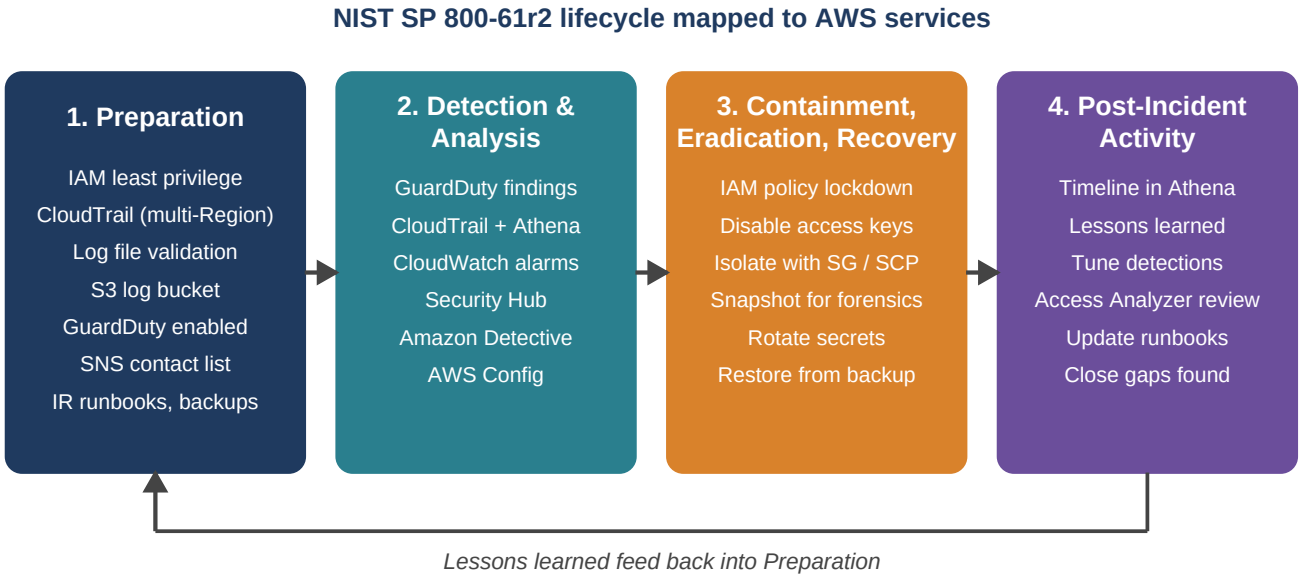

Figure 1. The four NIST SP 800-61r2 phases and the AWS services that support each one.

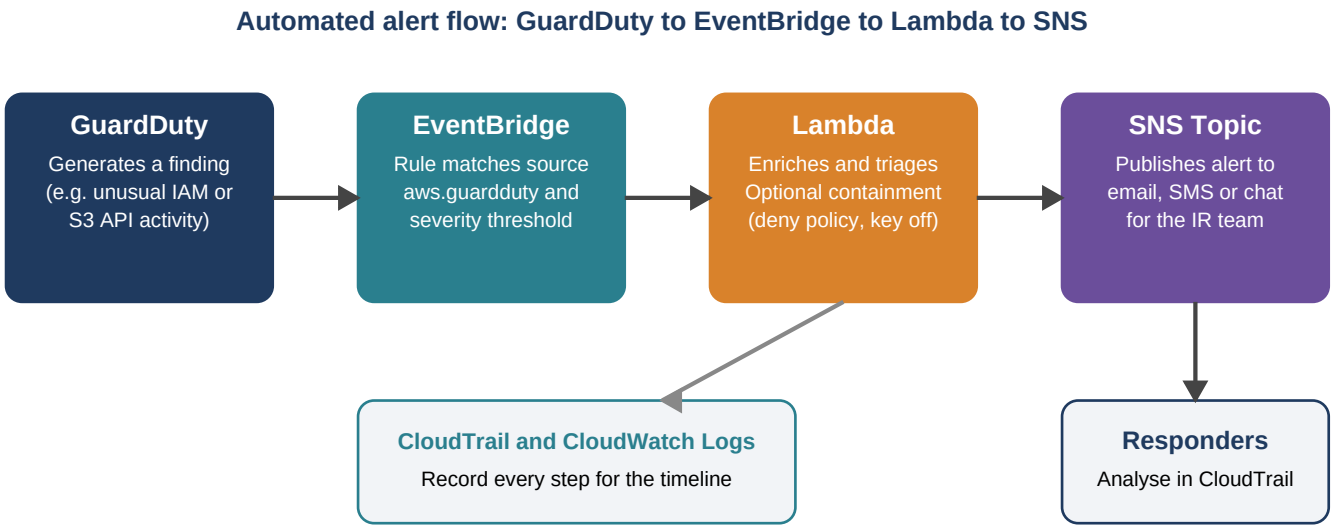

Figure 2. How a GuardDuty finding becomes a notification and, optionally, an automated containment action.

Phase-to-Service Mapping

Phase	Purpose	AWS services and actions
1. Preparation	Be ready before an incident happens.	IAM least privilege and MFA; multi-Region CloudTrail with log file validation delivering to a protected S3 bucket; GuardDuty and Security Hub enabled; SNS topics for responder contact; documented runbooks; backups and tagged resources.
2. Detection & Analysis	Notice suspicious activity and decide whether it is a real incident.	GuardDuty findings; CloudTrail events queried in Athena; CloudWatch metric filters and alarms; Security Hub aggregation; Amazon Detective for investigation; AWS Config for configuration changes.
3. Containment, Eradication & Recovery	Stop the spread, remove the cause and restore normal service.	IAM policy lockdown (deny-all policy, revoked sessions); disabling access keys; isolating with security groups or SCPs; EBS snapshots for forensics; rotating secrets in Secrets Manager; restoring from clean backups.
4. Post-Incident Activity	Learn from the incident and improve.	Incident timeline rebuilt from CloudTrail and Athena; lessons-learned review; tuning of GuardDuty, EventBridge and CloudWatch rules; IAM Access Analyzer review; updated runbooks and Config rules.

Summary of Each Phase

Preparation. This phase makes an effective response possible before anything goes wrong. In AWS it means enforcing least-privilege IAM, turning on a multi-Region CloudTrail with log file validation, enabling detection services such as GuardDuty, and agreeing who gets notified and what they should do. Without it, responders lose time finding logs, permissions and contacts while an incident is already under way.

Detection & Analysis. This phase identifies suspicious activity and confirms whether it is a real incident. GuardDuty raises findings, and CloudTrail, Athena and CloudWatch let analysts check them against the raw events, for example unusual IAM user creation or bursts of S3 requests from one IP. The aim is to understand scope and severity quickly, using evidence and not assumption, so that the right response can be chosen.

Containment, Eradication & Recovery. This phase limits the damage, removes the attacker's access and restores services. In AWS, containment is often an IAM action, such as attaching a deny policy, disabling access keys or revoking active sessions, or isolating a resource with a security group. Eradication removes persistence such as unauthorised users or roles, and recovery restores from clean backups and rotates exposed credentials. Evidence such as snapshots and logs is preserved before anything is deleted.

Post-Incident Activity. This phase turns the incident into improvement. The team rebuilds a timeline from CloudTrail, reviews what worked and what did not, and updates detection rules, IAM permissions and runbooks. The lessons feed back into Preparation, which makes the lifecycle a cycle and not a one-way process.

Alert Flow in AWS (Figure 2)

GuardDuty analyses CloudTrail, VPC flow and DNS data and produces a finding when it sees suspicious behaviour. An Amazon EventBridge rule matches findings from the source *aws.guardduty*, optionally filtered by severity, and forwards them to a Lambda function. The Lambda function enriches the finding, decides how serious it is and can take a pre-approved containment action, such as attaching a deny policy to an IAM user or deactivating an access key. It then publishes a message to an SNS topic, which notifies the incident response team by email, SMS or chat. Every step is recorded in CloudTrail and CloudWatch Logs, which provides the evidence for the later timeline. Automated containment should be limited to well-tested, low-risk actions, and an analyst should confirm anything uncertain.

Note: this document is a theory and methodology overview. The flow shown is a reference design and was not deployed in this phase.